

EU Regulatory & Compliance Framework for Insurance Fraud Analytics

Obligations governing the use of personal data and automated analytics to detect insurance fraud across the EU/EEA

Document reference	COMP-EU-FRAUD-2024
Version	1.0 (approved)
Owner	Group Data Protection Office
Approver	Group Chief Compliance Officer
Applies to	Automated and analyst-assisted fraud detection, EU/EEA
Effective date	01 February 2025
Next review	01 February 2026

Synthetic teaching material for a workshop — not legal advice. Deliberately generalised.

1. Purpose and Scope

This framework sets out the regulatory obligations and internal controls that apply when the firm uses personal data and automated analytics to detect, investigate and act upon suspected insurance fraud within the European Union and wider EEA. It covers the full lifecycle implemented in this workshop: ingestion into **Bronze**; cleaning and enrichment into **Silver** and **Gold** (including **fraud_risk_score** and the four risk flags); natural-language querying via Genie; and analyst decisions to pay, deny or refer a claim.

The dataset contains both non-personal claim attributes (policy_type, claim_amount, region) and **personal data** relating to identifiable individuals (policyholder_id, full_name, date_of_birth, email, phone, credit_score), bringing the activity within the GDPR.

2. Governing Instruments

2.1 General Data Protection Regulation (Regulation (EU) 2016/679)

The GDPR is the central instrument. Fraud prevention is expressly recognised as a legitimate interest (Recital 47). The firm typically relies on **Article 6(1)(f) legitimate interests**, supported by a documented Legitimate Interests Assessment, and **Article 6(1)(c) legal obligation** where anti-fraud law compels processing. Where special-category data is involved (Article 9), e.g. health data in a Health claim, an additional condition is required.

2.2 Article 22 — Automated Decision-Making

Article 22 grants the right not to be subject to a decision based *solely* on automated processing producing legal or similarly significant effects — and denying a claim is such an effect. **Control implication:** the **fraud_risk_score** is used only to **triage and rank** claims for human review; it must never auto-deny a claim. A qualified analyst makes the final disposition, preserving the safeguards in Article 22(2)–(3).

2.3 EU AI Act (Regulation (EU) 2024/1689)

AI systems used for risk assessment and pricing in life and health insurance are treated as high-risk, attracting obligations on data quality, logging, transparency, human oversight and accuracy. A fraud-triage model materially affecting access to an insurance benefit should be assessed against these obligations; the Act's principles are sound practice even where a system is not formally high-risk.

2.4 Sector and financial-crime rules

- Insurance Distribution Directive (Directive (EU) 2016/97) — conduct and customer-treatment obligations constraining how fraud suspicion is acted upon.
- Anti-Money-Laundering framework (Directive (EU) 2015/849 as amended) — suspicious activity reporting where fraud intersects with money laundering.

3. Data-Protection Principles Applied

- **Lawfulness, fairness, transparency** — the privacy notice must disclose fraud processing; analytics must not discriminate against protected groups.
- **Purpose limitation** — data collected for underwriting/claims may be reused for fraud detection (compatible, disclosed) but not silently repurposed for marketing.
- **Data minimisation** — the Silver layer deliberately drops direct-contact PII (email, phone), retaining only region, tenure, credit score and age.
- **Accuracy** — data-quality expectations (unique non-null claim_id, claim_amount > 0, report_date ≥ claim_date, is_fraud ∈ {0,1}) support this principle directly.
- **Storage limitation** — investigation records retained only as long as necessary, then deleted or anonymised.
- **Integrity & confidentiality** — Unity Catalog enforces table/column access; the app runs under a least-privilege service principal; all access is auditable.
- **Accountability** — demonstrated via this framework, the LIA, a DPIA, Unity Catalog lineage and an audit trail of analyst decisions.

4. Mapping Data Fields to Compliance Categories

Data field	Category	Notes
policyholder_id	Pseudonymous ID	Personal data when linkable to a person
full_name, email, phone	Direct PII	Minimised — dropped from Silver policyholders
date_of_birth / customer_age	Personal data	Age can proxy protected traits — monitor
credit_score	Personal (financial)	Sensitive; drives low_credit_flag
region	Personal (location)	Watch for geographic proxy discrimination
gender	Special-category-adjacent	Must not drive fraud decisions
claim_amount, policy_type	Non-personal	Low risk
fraud_risk_score, is_fraud	Derived / label	Governed by Article 22 safeguards

5. Required Controls

- Current DPIA (Article 35) and documented Legitimate Interests Assessment.
- Record of Processing Activities (Article 30).
- Human oversight: automated scores triage but never auto-deny.
- Fairness testing across protected characteristics to detect disparate impact.
- Least-privilege access via Unity Catalog; PII masking where feasible; full audit logging.
- Explainability: the additive, named-flag fraud_risk_score is preferred over an opaque model.

6. Data Subject Rights & Breach Response

Data subjects retain rights of information, access, rectification, objection and the Article 22 safeguards. Access may be lawfully restricted where disclosure would tip off a fraudster, provided the restriction is

necessary, proportionate and recorded. Any personal-data breach must be assessed within the GDPR 72-hour notification window (Article 33) and, where high risk arises, affected individuals notified (Article 34).

Approved by the Group Chief Compliance Officer. This document is reviewed annually or upon material regulatory change.